ALEXANDRE Ewan, Groupe 1
13/10/2026

TP2.9 : Test d'intrusion : Phase VII Rapport

Table des matières

1) Problématique 1
2) Rédaction détaillée 1
I. Comment rédiger un bon rapport de pentest 1
II. Le rapport d'exécution (sommaire exécutif) 2
III. Le rapport technique détaillé 2
IV. L'audit de sécurité global et les référentiels professionnels (PTES) 3
3) Conclusion 4

1) Problématique

Nous cherchons à comprendre comment rédiger un bon rapport de test d'intrusion après avoir terminé l'ensemble des étapes techniques. Pour cela, nous allons voir comment présenter nos résultats de façon claire aussi bien pour les équipes techniques que pour les dirigeants, comment organiser le document entre sommaire exécutif et rapport technique détaillé, et sur quels référentiels professionnels s'appuyer pour mener un audit complet.

2) Rédaction détaillée

I. Comment rédiger un bon rapport de pentest

Une fois que le test d'intrusion est terminé, la rédaction du rapport est l'étape la plus importante de la mission. C'est ce document qui va permettre au client d'avoir un retour détaillé sur l'état réel de sa sécurité et de savoir quoi corriger. Dans certains cas, on collabore aussi avec d'autres pentesteurs pour regrouper toutes les découvertes.

Le rapport doit s'adresser à deux types de personnes très différents dans l'entreprise :
- L'équipe informatique (IT, administrateurs réseau et développeurs), qui a besoin de tous les détails techniques précis pour corriger les vulnérabilités.
- Les dirigeants de l'entreprise (DSI, direction générale), qui ne sont pas forcément techniques mais qui doivent comprendre les risques réels et décider des priorités et des budgets.

C'est pour cela qu'il faut éviter le jargon incompréhensible et les acronymes réservés aux spécialistes quand on parle de l'impact global. Par exemple, dire clairement « il a été possible d'accéder à vos courriels et aux données confidentielles » parle beaucoup plus aux décideurs que n'importe quelle explication technique complexe.

Au niveau du format, le rapport global est généralement fourni en PDF non modifiable (en français ou en anglais), avec une mention 'Confidentiel' en filigrane car le document contient des informations sensibles permettant de s'introduire dans le système de l'entreprise.

II. Le rapport d'exécution (sommaire exécutif)

Le sommaire exécutif résume les points clés pour la direction sans entrer dans les lignes de commande. Il contient les éléments suivants :
- Background : description du but des tests et définitions simples des termes pour les exploitants (par exemple définir ce qu'est une vulnérabilité et une contre-mesure).
- Posture globale : vue d'ensemble de l'efficacité de la sécurité, failles majeures découvertes (comme l'exploitation de la vulnérabilité Microsoft MS08-056) et causes générales (manque de mises à jour ou de correctifs).
- Profil du risque : classification générale de la sécurité de l'organisation comparée à des sites similaires, mesurée avec des indicateurs explicites du type 'high', 'medium', 'low'.
- Découvertes générales : descriptif avec des statistiques et métriques sur l'efficacité des contre-mesures déployées.
- Recommandations sommaires et plan stratégique : vue de haut niveau des tâches requises et des objectifs court et long termes pour renforcer la sécurité.

Il est très intéressant de résumer le nombre de failles trouvées dans un format tabulaire de synthèse, en les triant par niveau de priorité, difficulté de correction et sévérité :

				Sévérité	Nombre
Niveau de priorité	**Nombre**	**Difficulté de correction**	**Nombre**	Intolérable	3
Urgent	5	Complexe	3	Substantielle	2
Standard	4	Modérée	5	Modérée	5
Bas	4	Facile	5	Acceptable	3

Ce tableau donne immédiatement une vue claire : par exemple ici, 5 failles ont une priorité urgente, 3 sont complexes à corriger et 3 présentent un niveau de sévérité intolérable.

III. Le rapport technique détaillé

Le rapport technique s'adresse directement aux équipes techniques chargées de corriger les failles. Il doit contenir au minimum les chapitres suivants :

Introduction : avec l'inventaire des détails tels que le périmètre exact du pentest (scope, adresses IP ciblées, serveurs autorisés), les dates des tests et les contacts désignés chez le client.

Récolte d'information : détails des informations récupérées durant la phase information-gathering (reconnaissance OSINT, cartographie des sous-domaines, ports ouverts et empreinte Internet du client).

Évaluation de vulnérabilités : détails des découvertes durant la phase vulnerability-analysis du test (analyse des failles trouvées à l'aide des scans automatisés comme Nmap et Nessus).

Vérification vulnérabilité / exploitation : détails des découvertes durant la phase d'exploitation du test (preuves de concept PoC, modules Metasploit utilisés pour valider que les failles sont réellement exploitables).

Post-exploitation : détails des découvertes de la phase post-exploitation du test (vérification des privilèges système avec getuid, extraction des empreintes de mots de passe SAM et techniques de maintien d'accès avec msfvenom).

Risques & dangers : une description détaillée des risques encourus. Cette section met en lumière les pertes possibles en cas d'attaque avérée par une personne malveillante (fuite de données personnelles, arrêt de la production, impact financier et réputationnel).

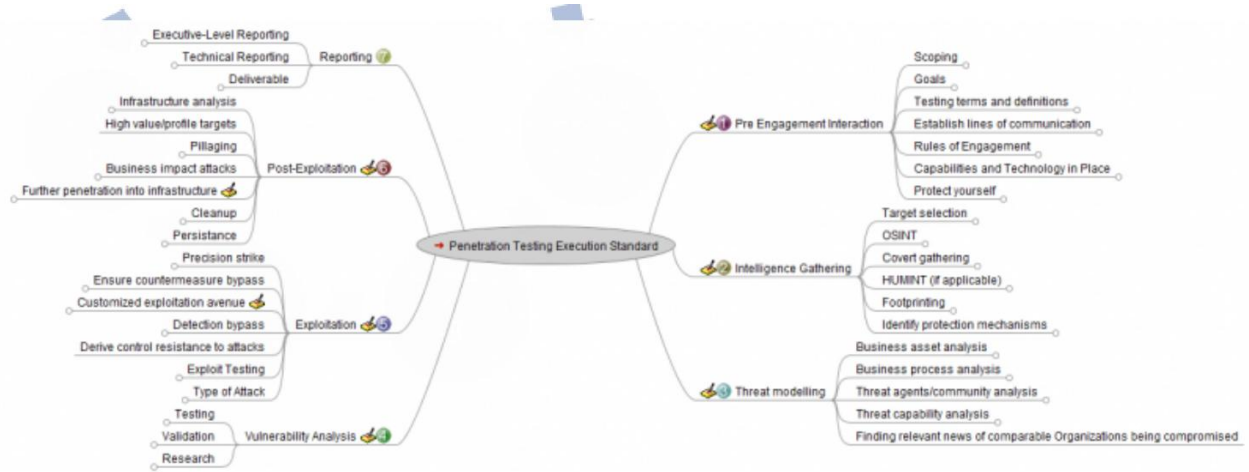
Conclusion technique : description globale des résultats du test et liste des recommandations techniques précises (correctifs, règles de pare-feu et configurations recommandées pour bloquer chaque faille découverte).

IV. L'audit de sécurité global et les référentiels professionnels (PTES)

Le test d'intrusion ne représente qu'une partie d'un audit de sécurité complet. En entreprise, un audit global comprend généralement d'autres phases :
- La correspondance orale et les entretiens avec les membres du système d'information (SI), la direction (DSI), le responsable de la sécurité (RSSI) et l'équipe technique.
- L'audit de configuration des services, des serveurs et des composants réseau (routeurs, switches, pare-feux).
- L'audit de code source pour les applications utilisées, déployées ou développées en interne par l'entreprise.

Pour encadrer toutes ces étapes, on s'appuie sur des référentiels et normes reconnus :
- ISO 27000 et ISO 27001 pour le management de la sécurité de l'information.
- Le Référentiel Général de Sécurité (RGS) de l'ANSSI.
- Le référentiel COBIT pour la gouvernance informatique.
- Les normes SOX et PCI-DSS (sécurisation des données de cartes bancaires et de paiement).

Concernant les techniques de pentest, on utilise le standard PTES (Penetration Testing Execution Standard - www.pentest-standard.org). Le cycle des différentes phases de pentesting est résumé par le schéma ci-dessous :



3) Conclusion

En conclusion, ce TP m’a permis de comprendre comment structurer et rédiger un rapport de test d'intrusion complet. J'ai appris qu'un bon rapport doit être double : un sommaire exécutif clair et sans acronymes compliqués pour permettre aux dirigeants de prendre des décisions, et un rapport technique détaillé étape par étape (de la récolte d'information jusqu'à la post-exploitation) pour permettre aux équipes IT de corriger les failles. Enfin, s'appuyer sur des référentiels comme le PTES et les normes ISO garantit un audit rigoureux et professionnel.